

Zero-Knowledge Trust

A framework for individual data sovereignty

Four concepts. A single idea.

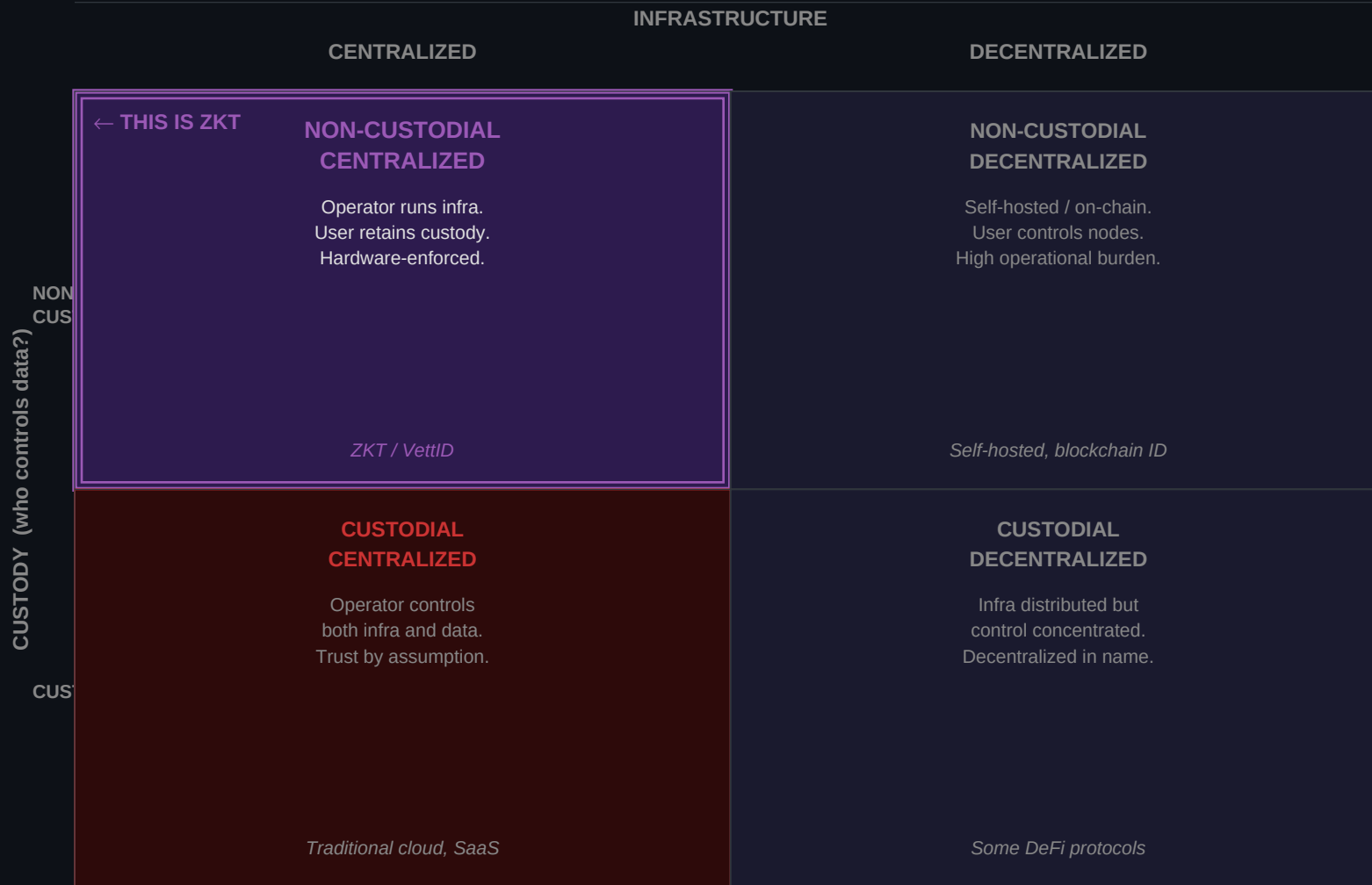
1 Data Sovereignty

2 Zero Direct Access

3 The Vine

4 LEASH

A third architectural model has emerged.



THE THIRD WAY

**Centralized infrastructure.
Decentralized control.**

*This is not a compromise.
It is a third way.*

WHAT MAKES IT POSSIBLE

- Trusted Execution Environments (TEEs)
- Hardware-enforced remote attestation
- User-controlled key derivation
- Ephemeral plaintext — no operator accumulation

The operator's role becomes that of a blind trustee: they keep the lights on, but they cannot see inside.

Who actually controls your data?

■ TRADITIONAL MODEL

Org-Centric Trust



WHO CONTROLS?

-> The organization

IF BREACHED?

-> Your data is exposed

CAN YOU DELETE?

-> Depends on the org

AUDIT TRAIL?

-> Theirs, if any

ZKT MODEL

Individual Sovereignty



WHO CONTROLS?

-> You

IF BREACHED?

-> They had nothing

CAN YOU DELETE?

-> You hold the keys

AUDIT TRAIL?

-> Yours, cryptographically sealed

What actually crosses the boundary?

TRADITIONAL

stored by the organization

ZKT — ONLY VERIFIED CLAIMS LEAVE

- **Age verified: over 18**
(no date of birth disclosed)

■ **Address: valid**
(no address disclosed)

■ **Creditworthy: yes**
(no financial records disclosed)

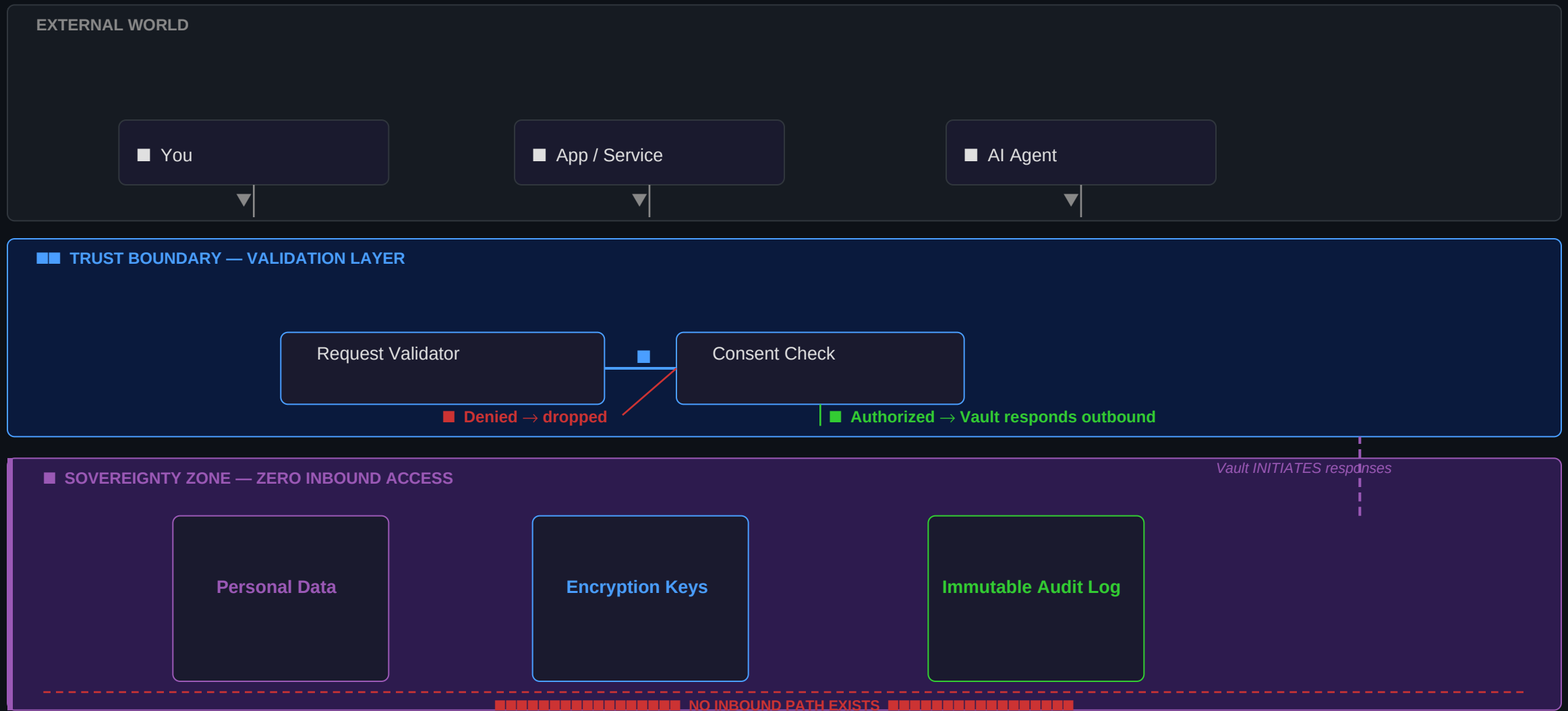
■ **Identity: verified**
(no document numbers disclosed)

used

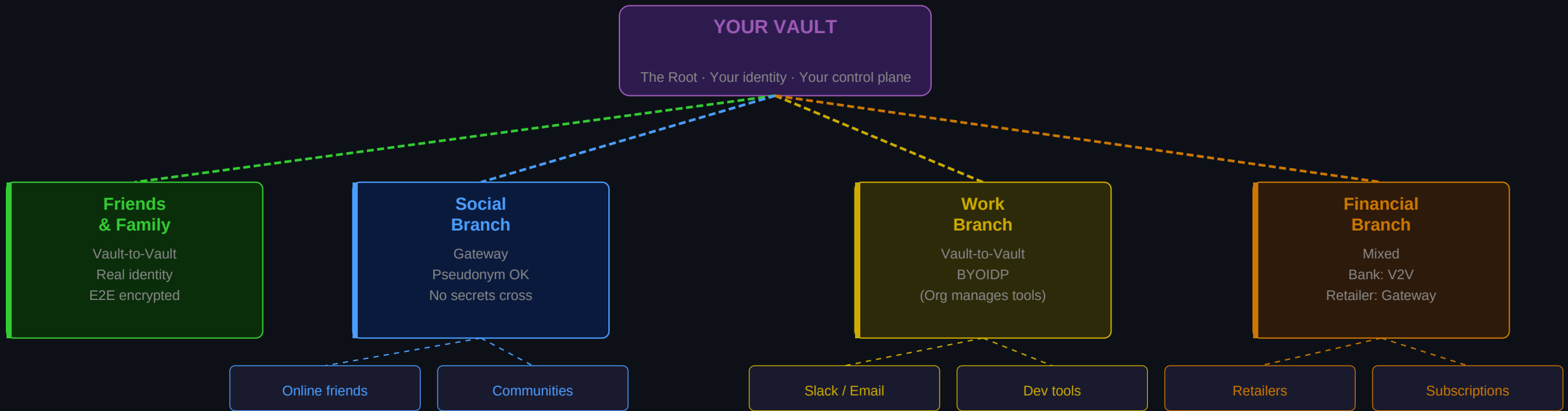
The power relationship is inverted.

Organizations receive proof of what they need — never the raw data behind it.

No door means no attack surface.



Your identity as a living structure.



The structure of your vine reflects the actual trust topology of your life.

One vault. One control plane. One audit trail. Depth of connection matches depth of trust.

Two connection types. Appropriate to the relationship.

GATEWAY (thin)

Low friction. Identity without exposure.

- ✓ Proves you are real
- ✓ Holds preferences in sandbox
- ✓ Pseudonym supported
- ✗ No access to your secrets
- ✗ No raw personal data stored

*Best for: services, apps, platforms,
retailers — any org that needs identity
but not secrets*

VAULT-TO-VAULT (deep)

Real trust. Real identity. Real channel.

- ✓ Full encrypted channel
- ✓ Real identity (your choice)
- ✓ Secrets can be shared
- ✓ Mutual audit trail
- ✓ Co-signing possible
- ✓ Hardware isolation available

*Best for: real relationships,
employers, financial institutions,
trusted parties*

Services grow too:

A service starts as a gateway (low friction on-ramp). As trust grows, it can become a proper vault. The architecture supports both.

AI agents need credentials. Today that's a problem.

TODAY'S MODEL — AGENTS HOLD THE KEYS

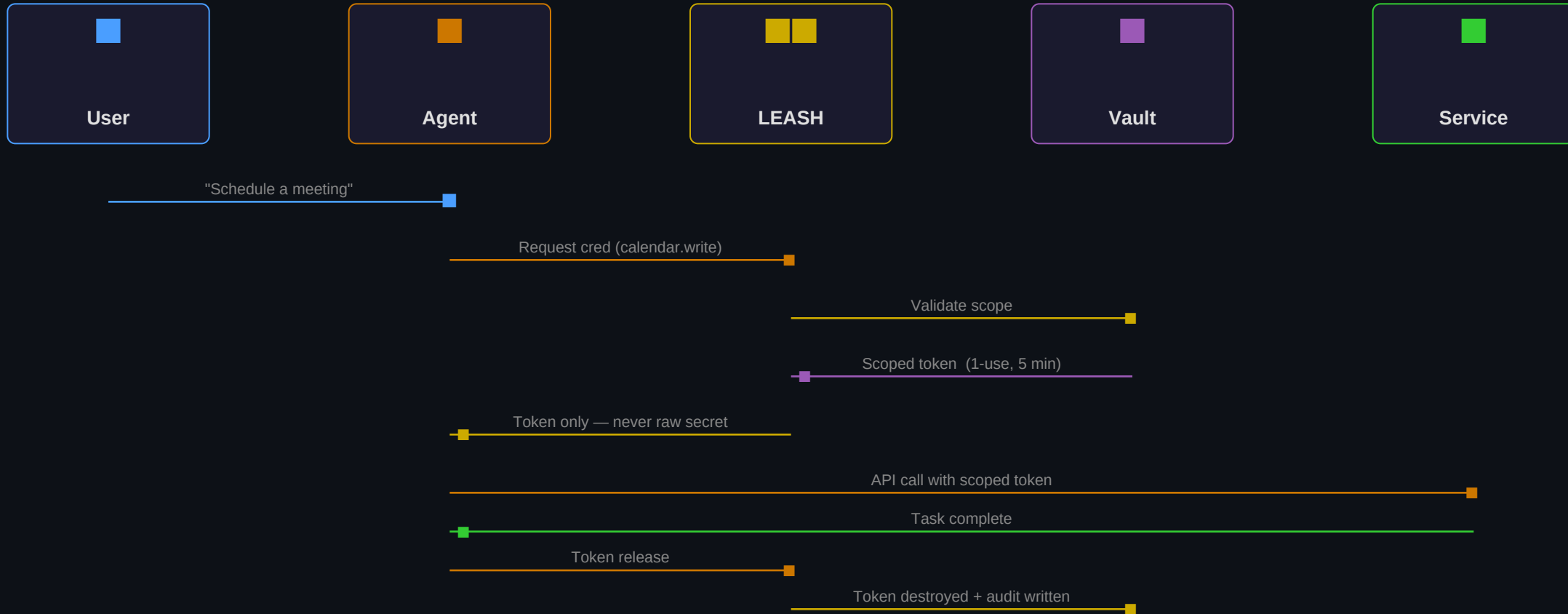
- ✗ API keys stored in environment variables — readable by anything in the process
- ✗ Secrets in config files — version controlled, emailed, copied, forgotten
- ✗ Tokens with full account access and no expiry
- ✗ No audit trail of what the agent actually used the credential for
- ✗ One compromised agent = full account access. Forever.

What if the agent could do useful work without ever holding the secret?

That's the LEASH model. Lightweight Encrypted Agent Secret Handling.

Authorization lives in the vault. The agent borrows permission — it never owns it.

The agent borrows permission. It never owns it.



The vault never exposed the real credential. The agent never held it.

Full audit trail. User can revoke at any time. Scope is defined by the user — not the agent.

What if the agent is compromised?

TRADITIONAL MODEL

Attacker finds:

API_KEY="sk-prod-xxxxxxxxxxxxxxxxxx"

in .env file / shell history / container image

Value: FULL ACCOUNT ACCESS. FOREVER.

Every action the agent could take — the attacker can now take.

No audit trail. No revocation. No limit.

LEASH MODEL

Attacker finds:

expired single-use scoped token

valid for: calendar.write · TTL: 5 min · already used

Value: ZERO. Vault is untouched.

Audit log shows exactly what happened and when.

User revokes from their phone. Done.

A compromised agent cannot exfiltrate secrets it never had.

The attack surface collapses. The vault is structurally isolated from the agent's failure domain.

USER CONTROLS

- Scope — which secret types the agent may access
- Approval mode — auto-approve vs. manual per request
- Rate limits — how often the agent can request

One framework.

Individual sovereignty at every layer.

Data Sovereignty: You are the custodian. Not the organization.

Zero Direct Access: No door. No attack surface.

The Vine: Trust depth matches relationship depth.

LEASH: Agents borrow permission. They never own it.